SteelCentral™ AppResponse 11

Security Overview

Version 11.18.0

March 2024

riverbed®

© 2024 Riverbed Technology. All rights reserved.
Riverbed®, SteelApp™, SteelCentral™, SteelFusion™, SteelHead™, SteelScript™, SteelStore™, Steelhead®, Cloud Steelhead®, Virtual Steelhead®, Granite™, Interceptor®, Stingray™, Whitewater®, WWOS™, RiOS®, Think Fast®, AirPcap®, BlockStream™, FlyScript™, SkipWare®, TrafficScript®, TurboCap®, WinPcap®, Mazu®, OPNET®, and Cascade® are all trademarks or registered trademarks of Riverbed Technology, Inc. (Riverbed) in the United States and other countries. Riverbed and any Riverbed product or service name or logo used herein are trademarks of Riverbed. All other trademarks used herein belong to their respective owners. The trademarks and logos displayed herein cannot be used without the prior written consent of Riverbed or their respective owners.

This software ("Software") and this document together with the end user or technical documentation pertaining to the Software that is provided by Riverbed with the Software or otherwise made available by Riverbed (collectively, the "Documentation") are licensed subject to the terms and conditions of the Riverbed customer agreement available at www.riverbed.com/license, including without limitation the additional terms and conditions set forth at www.riverbed.com/license/additional_use_rights. No other rights or licenses are granted to the Software or Documentation except as set forth in the foregoing terms and conditions. Riverbed and its licensors and suppliers retain all right, title, and interest in and to the Software and Documentation.

riverbed

Riverbed Technology
680 Folsom Street
San Francisco, CA 94107
www.riverbed.com

Contents

General Overview/Introduction To Security For AppResponse 11 1

Simple Generic Security Practices 1

- Restrict Physical Access To An Appliance 1
- Restrict Network Access To A System 1
- Warn Against Unauthorized Access 2
- Other Best Practices 2

Preventing Intrusion Via The Network 2

Authentication 3

- User Accounts 4
- Roles and Access Privileges 4
- Password Policies 4
- Authentication Methods 5

SAML: Overview and Recommended Practices 6

Audit Logs: Configuration and Use 7

SSL/TLS 7

SSL Decryption 7

Secure Communication With AppResponse 11 7

- Secure Vault 8
- SSL Ciphers Supported For Decryption 8

REST API Security 13

SNMP 13

- Supported AppResponse Platforms 13
- General Considerations When Using FIPS Mode 14
- Traffic Handling 14
- Enabling FIPS Mode 14
- Feature Support 14

How to Report a Discovered Vulnerability 17

How to Wipe a System 18

AppResponse 11 Security Overview

General Overview/Introduction To Security For AppResponse 11

This document describes a set of recommended practices for securing your AppResponse 11 system against unauthorized access. Practices for physical appliances, VM-hosted systems, and cloud-based systems are covered.

Note: In this document, the term "system" refers to any instance of AppResponse 11 (physical hardware, VM-hosted, or cloud-based), while "appliance" refers exclusively to a physical AppResponse 11 hardware unit, including dedicated Storage Units. The supported AppResponse 11 appliances are:

- AppResponse 1200, 2200, 3300, 3800, 4300, 5100, and 6000 Appliances
- AppResponse xx70 Appliances
- AppResponse xx80 Appliances
- Storage Units: SCAN-SU-4, SCAN-SU-10, SCAN-SU-48T, SCAN-SU-72T, and EXP-300

Simple Generic Security Practices

This section describes the simplest measures you can take to secure your AppResponse 11 system, before you begin changing the system's configuration. Configuration changes that block sophisticated attempts to access the system remotely are imperative, but are rendered superfluous if it's possible for an unauthorized person to walk up to an appliance and connect to its console port, or if an outdated web browser with a security flaw furnishes a non-obvious attack vector.

Restrict Physical Access To An Appliance

When using an AppResponse 11 appliance, make certain to install it in a secure location to which it is possible to restrict physical access to authorized personnel only. Restricting physical access to the appliance reduces the likelihood of forms of tampering such as unauthorized connection to a hardware interface, removing hard disks, and unscheduled reboots.

Restrict Network Access To A System

If your network management tools support the practice, define a network policy that allows access to the AppResponse 11 system only from specific IP addresses and subnets, and denies any access to all others. In this way, you can restrict the visibility and availability of the AppResponse 11 system's dashboards and configuration exclusively to users of explicitly allowed subnets.

Warn Against Unauthorized Access

Use the Administration > Authentication page in the AppResponse 11 web UI to define a login banner message that warns users against unauthorized access to the system. This will display a message as each user logs in, formally notifying them of any conditions or requirements associated with their use of the system, as well as any penalties for unauthorized access or deliberate misuse. *No default login banner is provided; if you wish to use one, you must define it explicitly.*

Other Best Practices

The following practices furnish additional simple safeguards against unauthorized access:

- ***Change the web session inactivity timeout:*** *By default, the session inactivity timeout is enabled and set for 60 minutes.* Use the Web Session Inactivity Settings on the Administration > Authentication page in the AppResponse 11 web UI to specify a time interval (in minutes) after which a user's web session will be logged out automatically if it has been idle for that long. A logged out user will need to re-enter their username and password to resume the web session.
- ***Enable screen locking on client devices:*** Client devices used to access an AppResponse 11 system should have screen locking enabled, preventing use after a configured period of inactivity. Unlocking the screen should be subject to successful entry of a non-default password.
- ***Install software/security updates when they're available:*** In general, install software and security updates for AppResponse 11, as well as for your client devices, as soon as they become available. This includes the client's operating system and web browsers. Software updates often include security enhancements, and staying up to date with the latest available software, both for AppResponse 11 and client devices, can prevent unauthorized access via subtle or seemingly unrelated vulnerabilities.

Preventing Intrusion Via The Network

After you've addressed the simplest, least sophisticated ways your AppResponse 11 system can be compromised, you're ready to begin changing its configuration to secure it against more sophisticated attempts at unauthorized access over the network.

HTTP access to AppResponse 11 is disabled by default. You can enable it using the web UI at Administration > System Settings: General, in the Web Server Settings tab.

SSH access to AppResponse 11 is enabled by default. You can disable it using the `no sshd enable` CLI command. SSH can be re-enabled using the `sshd enable` CLI command.

AppResponse 11 does not enable you to restrict SSH, web UI, or REST access by IP address.

If you lock down your network on a port-by-port basis, ensure that the following ports are open between AppResponse 11 and other systems it must communicate with:

- TCP/22 – (SSH) Command Line Interface.
- TCP/25 – (SMTP) Email. *By default, AppResponse 11 contacts an SNMP server at port 25.* This can be changed in the web UI at Administration > System Settings: General, in the Email tab.

- TCP/443 – (HTTPS) *By default, AppResponse 11 uses port 443 for HTTPS.* This can be changed in the web UI at Administration > System Settings: General, in the Web Server Settings tab. This includes:
  - AppResponse 11 web UI and control from SteelCentral Packet Analyzer Plus.
  - SteelCentral NetProfiler contacts AppResponse 11.
  - SteelCentral Portal contacts AppResponse 11.
  - ServiceNow integration: The ServiceNow URL is user-configured, typically, TCP/443. Configure a ServiceNow recipient in the web UI at Definitions > Recipients.
- TCP/41017 – AppResponse 11 contacts SteelCentral NetProfiler. AppResponse 11 exports flow records directly to a NetProfiler Base module, AN module, Dispatcher module, or a Flow Gateway on this port. Exporting flow records from AppResponse 11 to NetProfiler via a Flow Gateway is considered best practice to take advantage of regionalized Flow Gateways and deduplication.
- TCP – (SAML) AppResponse 11 contacts a SAML authentication server on the HTTPS port specified in the IDP metadata used to configure SAML on AppResponse 11. Configure SAML in the web UI at Administration > Account Management: Authentication, in the SAML 2.0 tab.
- UDP/123 – (NTP) Time synchronization.
- UDP/161 – (SNMP) AppResponse 11 listens for MIBs.
- UDP – (SNMP) Configure an SNMP trap recipient in the web UI at Definitions > Recipients, specifying the appropriate UDP port for that listener.
- UDP/319 and 320 – (PTP) Time synchronization.
- UDP/514 – (Syslog) *By default, AppResponse 11 contacts a Syslog server at port 514.* This can be changed in the web UI at Definitions > Recipients.
- UDP/1812 – (RADIUS) *By default, AppResponse 11 contacts a RADIUS server at port 1812.* This can be changed in the web UI at Administration > Account Management: Authentication, in the RADIUS tab.
- UDP – (TACACS+) AppResponse 11 contacts a TACACS+ server over UDP on the port specified when configuring TACACS+ on AppResponse 11. Configure TACACS+ in the web UI at Administration > Account Management: Authentication, in the TACACS+ tab.
- UDP – (NetFlow export) – AppResponse 11 exports NetFlow v9 records to other flow collectors over a configurable UDP port that the flow collector listens on.

Authentication

AppResponse 11 provides robust support for controlling access by individual users.

Unless you are using SAML (single sign-on), user management is the same across HTTPS, REST, and CLI, through serial, monitor/keyboard, and SSH interfaces.

User Accounts

By default, AppResponse 11 provides a single user account and password: The user name is admin*, and the default password is* admin*. This user account is assigned the built-in role of System Administrator, which provides the* admin *user account with unrestricted access to all AppResponse 11 features and data.*

At a minimum, change the default password to something less obvious and more complex. The default password is provided solely to enable you to log in to the system and begin changing the configuration.

Change the default password using the web UI by opening the Administration > Account Management: User Administration page. Click the Local Users tab and edit the admin user account. When the Edit User: admin dialog appears, click Change Password. Type the old password ("admin"), then type and re-type the new password. Click Apply to make the change take effect immediately. The next time you log in with the admin account, you will need to type the new password.

Additional user accounts can be created and configured on the Administration > Account Management: User Administration page, also. You should create some user roles, first, though, as the only user role provided by default is System Administrator, which provides unrestricted ("Full Control") access to all AppResponse 11 features and data.

Roles and Access Privileges

By default, AppResponse 11 provides a single built-in role: System Administrator, which provides unrestricted ("Full Control") access to all AppResponse 11 features and data. To implement roles that enable access to some features ("View Only" or "Full Control") but restrict access to others ("View Only" or "No Access"), you need to define additional user roles explicitly.

Role Based Access Control (RBAC) protects AppResponse 11 by assigning different access privileges to different user roles. User roles are then assigned to user accounts as they are created. A user's privileges on the system are determined by which roles the system administrator assigns to their account. Each user account can be assigned one or more roles.

Define user roles using the web UI at: Administration > Account Management: User Administration (Roles and Permissions tab).

A new role begins with "No Access" for each category of functionality; defining a new role is a matter of adding access (either "View Only" or "Full Control") for specific functionality categories. Changing the access associated with a role changes access for every user account that is assigned that role.

Password Policies

By default, AppResponse 11 has no password policy defined. This means that there are no restrictions or conditions on password length, character requirements, reuse, and other related considerations. To ensure that users define adequately secure passwords, you must define a password policy explicitly. These password policies apply to local user accounts only; when remote authentication or SAML is used, that remote authentication service enforces its own password policies. Password policies affect all access methods (web UI and CLI).

Configure password policies using the web UI at: Administration > Account Management: User Administration (Password Policy tab). The controls on that page enable you to define the requirements that user-defined passwords must meet when they are created or changed. These requirements can include minimum length, minimum number of lowercase and uppercase characters, minimum number of digits, minimum number of symbol characters, minimum number of character changes, maximum number of repeated characters, restriction on including common words, and the number of previous passwords to check to prevent the reuse of old passwords. Take the time to define a prudent set of requirements that ensures that users create strong passwords that cannot be guessed easily or brute force broken.

Authentication Methods

By default, AppResponse 11 supports the use of local user accounts, which AppResponse 11 authenticates using passwords that are configured and stored on the AppResponse 11 system. AppResponse 11 supports the use of three authentication methods in addition to local user accounts: RADIUS, TACACS+, and SAML. If you use one or more of these authentication methods, you must configure them explicitly.

Note: If you enable SAML 2.0 authentication, RADIUS, TACACS+, and local authentication all will be disabled for the web UI, and only the SAML identity provider will authenticate users.

SAML is described separately in the section that follows this one.

Access the authentication pages in the web UI at Administration > Account Management: Authentication. A tab is provided for configuring each authentication method.

Configuring Authentication Precedence

The Authentication page's General tab provides a section titled, Authentication Types, that enables you to configure the precedence of the authentication methods you have in place.

When RADIUS and TACACS+ authentication servers are configured in AppResponse 11 you can add them to a sequence of authentication types (Local, RADIUS, or TACACS+) to be used when a user logs in. Authentication requests are made from the highest priority authentication type to the lowest. Within each authentication type, requests are made sequentially to the configured servers in the order in which they appear on the RADIUS and TACACS+ tabs. Authentication requests are made until a server accepts or rejects a request, or until the authentication types are exhausted.

- If a server does not respond, authentication proceeds to the next server.
- If authentication is rejected, there is no provision to try the next server of the same authentication type. For example, if two RADIUS servers are configured and the first server rejects a user, the second RADIUS server is not contacted. You can choose to try the next authentication type if a higher-priority authentication type rejects a request.

Note: Be careful that you don't lock yourself out of AppResponse 11 by doing either of the following:

- Removing Local authentication from the sequence and the remote servers (RADIUS or TACACS+) are unreachable.
- Clearing the "Try next method on reject:" check box.

If you lock yourself out of the system, contact Riverbed technical support. Riverbed recommends checking that authentication using RADIUS and TACACS+ works successfully before you remove local authentication or clear the "Try next method on reject." check box.

Refer to the *AppResonse 11 User's Guide* for complete details.

RADIUS

AppResponse 11 supports RADIUS authentication, but you must configure one or more RADIUS authentication servers explicitly.

Click Administration > Account Management: Authentication and click the RADIUS tab to add one or more RADIUS servers to the AppResponse 11 configuration.

TACACS+

AppResponse 11 supports TACACS+ authentication, but you must configure one or more TACACS+ authentication servers explicitly.

Click Administration > Account Management: Authentication and click the TACACS+ tab to add one or more TACACS+ servers to the AppResponse 11 configuration.

SAML: Overview and Recommended Practices

AppResponse 11 supports SAML authentication, but you must enable SAML explicitly and configure the SAML IDP. If you enable SAML authentication, RADIUS, TACACS+, and local authentication all will be disabled for the web UI, and only the SAML IDP will authenticate users.

SAML 2.0 authentication is supported to facilitate single sign-on for use with one or more AppResponse 11 systems or other Riverbed SteelCentral products accessed from a single browser session. When SAML 2.0 is enabled, AppResponse 11 relies on a specified SAML identity provider (IDP) for authentication, and does not use local authentication or RADIUS or TACACS+ servers in any combination. (Note that enabling SAML 2.0 authentication on AppResponse 11 disables all other forms of authentication used by the web UI.) If the SAML identity provider is unable to authenticate a user for any reason, that user will not be able to launch an AppResponse 11 web UI session. Note that SAML 2.0 authentication can be disabled via the AppResponse 11 CLI, using the `no saml enable` command.

When SAML 2.0 is enabled, the first time a user initiates access to an AppResponse 11 system in a browser session, AppResponse 11 will redirect the user to the SAML IDP for authentication. Upon successful authentication, the IDP will redirect the user back to the AppResponse 11 system, and the UI will open. The IDP will send back the user role corresponding to the user name being authenticated, and that user will have permissions in AppResponse 11 as defined by that role. As long as the user keeps that browser session active, any subsequent AppResponse 11 session, even if the user logs out of the system, quits the browser tab, or accesses a new system, will begin immediately without requiring the user re-authenticate. The user will need to re-authenticate with the IDP if they quit the browser session in which they had authenticated earlier.

Audit Logs: Configuration and Use

Audit logging is enabled for the AppResponse 11 system by default. The audit log records configuration changes made to the AppResponse 11 system using the CLI and web UI. By default, the audit log is configured to record all configuration changes. The associated details of the modified data/settings are the same for the two user interfaces, and include appropriate source/user/session information. If you do not wish to record all configuration changes, you can configure the audit log to omit specific changes.

It's recommended practice to have audit logging enabled so you have a record of exactly who accessed every resource on a system during an attempted breach.

Click Administration > System Status: Audit Trail to view the audit log for the system.

Click Administration > System Settings: System Operations and click the Audit Log Configuration tab to configure the audit log for the system. The Audit Log Configuration tab lists a large set of configuration object changes that can be logged; by default, all configuration objects are selected (enabled) for logging. Deselect one or more configuration objects if you don't feel it's necessary to record changes made to it. Controls are provided that enable you to specify the retention time and size of the log, as well as a control for specifying one or more external recipients of the audit log via Email, SNMP, or Syslog.

SSL/TLS

Access to the web UI and REST uses a TLS 1.2 encrypted channel, and the two interfaces share the same underlying HTTPS server. Although it is possible to enable SSL3 and TLS 1.0/1.1, this is strongly discouraged.

AppResponse 11 comes with a preconfigured set of enabled ciphers, and you can change the ciphers from the web UI or CLI using a cipher string that conforms to OpenSSL cipher string syntax.

Communication with NetProfiler uses a TLS1.2 encrypted channel. The cipher cannot be changed.

SSL Decryption

AppResponse 11 can be configured to decrypt the SSL communications of the packets captured from its monitoring ports. To do this, you need to provide AppResponse 11 with the private keys needed to decrypt the communications. The private keys are stored in the Secure Vault, cannot be extracted from the system (they are "write only") and have no relationship with the private key used for the HTTPS web server supporting the ARAppResponse 11 web UI and REST API.

Secure Communication With AppResponse 11

AppResponse 11 supports secure storage of keys and certificates, as well as decryption of secure communications with other entities.

Secure Vault

AppResponse 11's Secure Vault feature cryptographically encrypts secret keys and certificates stored on the local disk. The secured data is decrypted (unlocked) in memory after the system boots normally. If the vault cannot be unlocked, due to the system having been compromised, the web UI will be inaccessible. SAML authentication, SSL traffic decryption, and data export to NetProfiler also will not be functional. Administrator account login via SSH will be available for access to CLI commands.

The following pieces of secure information are stored in the Secure Vault:

- Web UI HTTPS certificate
- SSL decryption keys
- SSL certificates and keys for NetProfiler export
- SAML keys

Secure Vault uses “encfs” internally, at standard level. Standard mode uses the following settings:

- Cipher: AES
- Key Size: 192 bits
- PBKDF2 with 1/2 second runtime, 160 bit salt
- Filesystem Block Size: 1024 bytes
- Filename Encoding: Block encoding with IV chaining
- Unique initialization vector file headers
- File holes passed through

The password used internally (by Secure Vault) is deterministically produced based on properties of the system and cannot be changed.

SSL Ciphers Supported For Decryption

The default cipher string configuration for HTTPS on AppResponse 11 consists of:

- EECDH+AESGCM
- EDH+AESGCM
- AES256+EECDH
- AES256+EDH

These cipher strings can be modified in the web UI at Administration > System Settings: General in the Web Server Settings tab.

The following RSA ciphers are supported for decoding:

OpenSSL Name	IANA Name
EXP-RC4-MD5	TLS_RSA_EXPORT_WITH_RC4_40_MD5
RC4-MD5	TLS_RSA_WITH_RC4_128_MD5
RC4-SHA	TLS_RSA_WITH_RC4_128_SHA

OpenSSL Name	IANA Name
EXP-RC2-CBC-MD5	TLS_RSA_EXPORT_WITH_RC2_CBC_40_MD5
EXP-DES-CBC-SHA	TLS_RSA_EXPORT_WITH_DES40_CBC_SHA
DES-CBC-SHA	TLS_RSA_WITH_DES_CBC_SHA
DES-CBC3-SHA	TLS_RSA_WITH_3DES_EDE_CBC_SHA
AES128-SHA	TLS_RSA_WITH_AES_128_CBC_SHA
AES256-SHA	TLS_RSA_WITH_AES_256_CBC_SHA
NULL-SHA256	TLS_RSA_WITH_NULL_SHA256
AES128-SHA256	TLS_RSA_WITH_AES_128_CBC_SHA256
AES256-SHA256	TLS_RSA_WITH_AES_256_CBC_SHA256
CAMELLIA128-SHA	TLS_RSA_WITH_CAMELLIA_128_CBC_SHA
EXP1024-RC4-MD5	TLS_RSA_EXPORT1024_WITH_RC4_56_MD5
EXP1024-RC2-CBC-MD5	TLS_RSA_EXPORT1024_WITH_RC2_CBC_56_MD5
EXP1024-DES-CBC-SHA	TLS_RSA_EXPORT1024_WITH_DES_CBC_SHA
EXP1024-RC4-SHA	TLS_RSA_EXPORT1024_WITH_RC4_56_SHA
CAMELLIA256-SHA	TLS_RSA_WITH_CAMELLIA_256_CBC_SHA
SEED-SHA	TLS_RSA_WITH_SEED_CBC_SHA
AES128-GCM-SHA256	TLS_RSA_WITH_AES_128_GCM_SHA256
AES256-GCM-SHA384	TLS_RSA_WITH_AES_256_GCM_SHA384
CAMELLIA128-SHA256	TLS_RSA_WITH_CAMELLIA_128_CBC_SHA256
CAMELLIA256-SHA256	TLS_RSA_WITH_CAMELLIA_256_CBC_SHA256
AES128-CCM	TLS_RSA_WITH_AES_128_CCM
AES256-CCM	TLS_RSA_WITH_AES_256_CCM

The following Diffie-Hellman Ciphers ciphers are supported for decoding:

OpenSSL Name	IANA Name
DH-DSS-DES-CBC-SHA	TLS_DH_DSS_WITH_DES_CBC_SHA
DH-DSS-DES-CBC3-SHA	TLS_DH_DSS_WITH_3DES_EDE_CBC_SHA
DH-RSA-DES-CBC-SHA	TLS_DH_RSA_WITH_DES_CBC_SHA
DH-RSA-DES-CBC3-SHA	TLS_DH_RSA_WITH_3DES_EDE_CBC_SHA
DH-RSA-DES-CBC3-SHA	TLS_DH_RSA_WITH_3DES_EDE_CBC_SHA
EDH-DSS-DES-CBC-SHA	TLS_DHE_DSS_WITH_DES_CBC_SHA
EDH-DSS-DES-CBC3-SHA	TLS_DHE_DSS_WITH_3DES_EDE_CBC_SHA
EDH-RSA-DES-CBC-SHA	TLS_DHE_RSA_WITH_DES_CBC_SHA
EDH-RSA-DES-CBC3-SHA	TLS_DHE_RSA_WITH_3DES_EDE_CBC_SHA

OpenSSL Name	IANA Name
DHE-RSA-DES-CBC3-SHA	TLS_DHE_RSA_WITH_3DES_EDE_CBC_SHA
DH-DSS-AES128-SHA	TLS_DH_DSS_WITH_AES_128_CBC_SHA
DH-RSA-AES128-SHA	TLS_DH_RSA_WITH_AES_128_CBC_SHA
DHE-DSS-AES128-SHA	TLS_DHE_DSS_WITH_AES_128_CBC_SHA
DH-DSS-AES256-SHA	TLS_DH_DSS_WITH_AES_256_CBC_SHA
DH-RSA-AES256-SHA	TLS_DH_RSA_WITH_AES_256_CBC_SHA
DHE-DSS-AES256-SHA	TLS_DHE_DSS_WITH_AES_256_CBC_SHA
DHE-RSA-AES256-SHA	TLS_DHE_RSA_WITH_AES_256_CBC_SHA
DH-DSS-AES128-SHA256	TLS_DH_DSS_WITH_AES_128_CBC_SHA256
DH-RSA-AES128-SHA256	TLS_DH_RSA_WITH_AES_128_CBC_SHA256
DHE-DSS-AES128-SHA256	TLS_DHE_DSS_WITH_AES_128_CBC_SHA256
DH-DSS-CAMELLIA128-SHA	TLS_DH_DSS_WITH_CAMELLIA_128_CBC_SHA
DH-RSA-CAMELLIA128-SHA	TLS_DH_RSA_WITH_CAMELLIA_128_CBC_SHA
DHE-DSS-CAMELLIA128-SHA	TLS_DHE_DSS_WITH_CAMELLIA_128_CBC_SHA
DHE-RSA-CAMELLIA128-SHA	TLS_DHE_RSA_WITH_CAMELLIA_128_CBC_SHA
DHE-RSA-AES128-SHA256	TLS_DHE_RSA_WITH_AES_128_CBC_SHA256
DH-DSS-AES256-SHA256	TLS_DH_DSS_WITH_AES_256_CBC_SHA256
DH-RSA-AES256-SHA256	TLS_DH_RSA_WITH_AES_256_CBC_SHA256
DHE-DSS-AES256-SHA256	TLS_DHE_DSS_WITH_AES_256_CBC_SHA256
DHE-RSA-AES256-SHA256	TLS_DHE_RSA_WITH_AES_256_CBC_SHA256
DH-DSS-CAMELLIA256-SHA	TLS_DH_DSS_WITH_CAMELLIA_256_CBC_SHA
DH-RSA-CAMELLIA256-SHA	TLS_DH_RSA_WITH_CAMELLIA_256_CBC_SHA
DHE-DSS-CAMELLIA256-SHA	TLS_DHE_DSS_WITH_CAMELLIA_256_CBC_SHA
DHE-RSA-CAMELLIA256-SHA	TLS_DHE_RSA_WITH_CAMELLIA_256_CBC_SHA
DH-DSS-SEED-SHA	TLS_DH_DSS_WITH_SEED_CBC_SHA
DH-RSA-SEED-SHA	TLS_DH_RSA_WITH_SEED_CBC_SHA
DHE-DSS-SEED-SHA	TLS_DHE_DSS_WITH_SEED_CBC_SHA
DHE-RSA-SEED-SHA	TLS_DHE_RSA_WITH_SEED_CBC_SHA
DHE-RSA-AES128-GCM-SHA256	TLS_DHE_RSA_WITH_AES_128_GCM_SHA256
DHE-RSA-AES256-GCM-SHA384	TLS_DHE_RSA_WITH_AES_256_GCM_SHA384
DH-RSA-AES128-GCM-SHA256	TLS_DH_RSA_WITH_AES_128_GCM_SHA256
DH-RSA-AES256-GCM-SHA384	TLS_DH_RSA_WITH_AES_256_GCM_SHA384
DHE-DSS-AES128-GCM-SHA256	TLS_DHE_DSS_WITH_AES_128_GCM_SHA256
DHE-DSS-AES256-GCM-SHA384	TLS_DHE_DSS_WITH_AES_256_GCM_SHA384

OpenSSL Name	IANA Name
DH-DSS-AES128-GCM-SHA256	TLS_DH_DSS_WITH_AES_128_GCM_SHA256
DH-DSS-AES256-GCM-SHA384	TLS_DH_DSS_WITH_AES_256_GCM_SHA384
ECDH-ECDSA-RC4-SHA	TLS_ECDH_ECDSA_WITH_RC4_128_SHA
ECDH-ECDSA-DES-CBC3-SHA	TLS_ECDH_ECDSA_WITH_3DES_EDE_CBC_SHA
ECDH-ECDSA-AES128-SHA	TLS_ECDH_ECDSA_WITH_AES_128_CBC_SHA
ECDH-ECDSA-AES256-SHA	TLS_ECDH_ECDSA_WITH_AES_256_CBC_SHA
ECDHE-ECDSA-NULL-SHA	TLS_ECDHE_ECDSA_WITH_NULL_SHA
ECDHE-ECDSA-RC4-SHA	TLS_ECDHE_ECDSA_WITH_RC4_128_SHA
ECDHE-ECDSA-DES-CBC3-SHA	TLS_ECDHE_ECDSA_WITH_3DES_EDE_CBC_SHA
ECDHE-ECDSA-AES128-SHA	TLS_ECDHE_ECDSA_WITH_AES_128_CBC_SHA
ECDHE-ECDSA-AES256-SHA	TLS_ECDHE_ECDSA_WITH_AES_256_CBC_SHA
ECDH-RSA-NULL-SHA	TLS_ECDH_RSA_WITH_NULL_SHA
ECDH-RSA-RC4-SHA	TLS_ECDH_RSA_WITH_RC4_128_SHA
ECDH-RSA-DES-CBC3-SHA	TLS_ECDH_RSA_WITH_3DES_EDE_CBC_SHA
ECDH-RSA-AES128-SHA	TLS_ECDH_RSA_WITH_AES_128_CBC_SHA
ECDH-RSA-AES256-SHA	TLS_ECDH_RSA_WITH_AES_256_CBC_SHA
ECDHE-RSA-NULL-SHA	TLS_ECDHE_RSA_WITH_NULL_SHA
ECDHE-RSA-RC4-SHA	TLS_ECDHE_RSA_WITH_RC4_128_SHA
ECDHE-RSA-DES-CBC3-SHA	TLS_ECDHE_RSA_WITH_3DES_EDE_CBC_SHA
ECDHE-RSA-AES128-SHA	TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA
ECDHE-RSA-AES256-SHA	TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA
ECDHE-ECDSA-AES128-SHA256	TLS_ECDHE_ECDSA_WITH_AES_128_CBC_SHA256
ECDHE-ECDSA-AES256-SHA384	TLS_ECDHE_ECDSA_WITH_AES_256_CBC_SHA384
ECDH-ECDSA-AES128-SHA256	TLS_ECDH_ECDSA_WITH_AES_128_CBC_SHA256
ECDH-ECDSA-AES256-SHA384	TLS_ECDH_ECDSA_WITH_AES_256_CBC_SHA384
ECDHE-RSA-AES128-SHA256	TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA256
ECDHE-RSA-AES256-SHA384	TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA384
ECDH-RSA-AES128-SHA256	TLS_ECDH_RSA_WITH_AES_128_CBC_SHA256
ECDH-RSA-AES256-SHA384	TLS_ECDH_RSA_WITH_AES_256_CBC_SHA384
ECDHE-ECDSA-AES128-GCM-SHA256	TLS_ECDHE_ECDSA_WITH_AES_128_GCM_SHA256
ECDHE-ECDSA-AES256-GCM-SHA384	TLS_ECDHE_ECDSA_WITH_AES_256_GCM_SHA384
ECDH-ECDSA-AES128-GCM-SHA256	TLS_ECDH_ECDSA_WITH_AES_128_GCM_SHA256

OpenSSL Name	IANA Name
ECDH-ECDSA-AES256-GCM-SHA384	TLS_ECDH_ECDSA_WITH_AES_256_GCM_SHA384
ECDHE-RSA-AES128-GCM-SHA256	TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256
ECDHE-RSA-AES256-GCM-SHA384	TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384
ECDH-RSA-AES128-GCM-SHA256	TLS_ECDH_RSA_WITH_AES_128_GCM_SHA256
ECDH-RSA-AES256-GCM-SHA384	TLS_ECDH_RSA_WITH_AES_256_GCM_SHA384
DHE-RSA-AES128-CCM	TLS_DHE_RSA_WITH_AES_128_CCM
DHE-RSA-AES256-CCM	TLS_DHE_RSA_WITH_AES_256_CCM
ECDHE-ECDSA-AES128-CCM	TLS_ECDHE_ECDSA_WITH_AES_128_CCM
ECDHE-ECDSA-AES256-CCM	TLS_ECDHE_ECDSA_WITH_AES_256_CCM
ECDHE-RSA-CHACHA20-POLY1305	TLS_ECDHE_RSA_WITH_CHACHA20_POLY1305_SHA256
ECDHE-ECDSA-CHACHA20-POLY1305	TLS_ECDHE_ECDSA_WITH_CHACHA20_POLY1305_SHA256
DHE-RSA-CHACHA20-POLY1305	TLS_DHE_RSA_WITH_CHACHA20_POLY1305_SHA256
TLS_AES_128_GCM_SHA256	TLS_AES_128_GCM_SHA256
TLS_AES_256_GCM_SHA384	TLS_AES_256_GCM_SHA384
TLS_CHACHA20_POLY1305_SHA256	TLS_CHACHA20_POLY1305_SHA256
TLS_AES_128_CCM_SHA256	TLS_AES_128_CCM_SHA256
TLS_AES_128_CCM_8_SHA256	TLS_AES_128_CCM_8_SHA256

Certificate Management

By default, AppResponse 11's web UI and REST interface use a self-signed certificate generated when the system is first installed. The self-signed certificate can be regenerated using the web UI. In addition, a different certificate/private key can be imported using the web UI.

Communication with NetProfiler uses a default certificate; the certificate can be changed using the AppResponse 11 web UI, and the same change should be made on NetProfiler as well. Refer to the respective user guides for detailed instructions.

Make sure that you don't enable old ciphers or protocols like SSL 3.0 unless it's necessary for compatibility with older browsers or other products.

SSH ciphers are configurable using the CLI.

RADIUS and TACACS+ are old protocols that don't use strong cryptography when encrypting the credentials that go over the network.

REST API Security

The AppResponse 11 REST API shares a communication channel with the web UI, and uses the same authentication scheme as the web UI, unless you use SAML, in which case the REST API continues to use the normal RADIUS/TACACS/local authentication schemes.

SNMP

AppResponse 11 SNMP support is disabled by default. If you enable SNMP, you can specify the use of Version 1, Version 2c, or Version 3.

Enable SNMP using the web UI at Administration > System Settings: General, and click the SNMP tab. The Enable SNMP checkbox appears at the top of the tab.Note that SNMP v3 supports the use of user names, privilege levels, and authentication for trap notifications.

Recipients for SNMP traps are defined using the web UI at Definitions > Recipients.

FIPS Mode

This section describes the use of certified Federal Information Processing Standard (FIPS) cryptography on AppResponse 11 appliances.

AppResponse 11 supports the use of certified Federal Information Processing Standard (FIPS) cryptography. This feature uses a FIPS-140-3 compliant module (Riverbed cryptographic module 2.0), based on OpenSSL, for all cryptographic operations. FIPS affects any client that makes a secure connection to the appliance, including the web UI, Packet Analyzer Plus, NetProfiler, Portal, SSH, and raw REST calls over HTTPS. Precision Time Protocol (PTP) is not affected by this feature.

Setting FIPS to ON runs AppResponse 11 in FIPS mode, which means that, by default, only FIPS-approved ciphers and algorithms are used. Whenever non-approved algorithms (such as MD5) are used anyway, they use a non-FIPS-compliant implementation, and cannot be considered FIPS-compliant. Non-FIPS-compliant algorithms, when used, may not work as ordinarily expected.

Note: Enabling FIPS mode activates the use of FIPS on the system. However, individual features may require additional configuration in order to be properly FIPS-compliant; users are responsible for being familiar with what constitutes FIPS-compliance for each feature, and configuring it appropriately. Refer to comments in the “Feature Support” section that follows for more information. Be aware that AppResponse 11 will continue to operate even if one or more features have not been configured for FIPS-compliance; in such a case, the system will not provide any warning that a particular feature is not FIPS-compliant. Any exceptions to this behavior are noted in the “Feature Support” section.

Note: After FIPS is enabled, any SNMP traps configured to use MD5 authentication or AuthPriv security will not be delivered. Email notifications and SNMP traps configured to use other security levels still will be delivered.

Supported AppResponse Platforms

FIPS is supported on AppResponse hardware appliances and virtual systems. FIPS is not supported on AppResponse Cloud (AWS and Azure).

General Considerations When Using FIPS Mode

When FIPS mode is enabled, it affects many other AppResponse 11 behaviors. Be aware of the following considerations when using FIPS mode:

- Software updates cannot be performed when FIPS mode is on. AppResponse 11 can be updated after disabling FIPS mode.
- The message authentication codes that can be used for SSH in FIPS mode are listed in “SSH” on page 16.
- When connecting to the web UI and Packet Analyzer Plus in FIPS mode, only TLS1.2 is supported (out of TLS1.0/1.1/1.2, SSL2.0/SSL3.0).
- In FIPS mode, NTP is not FIPS-compliant when MD5 encryption is in use.
- Wireshark dissection is not FIPS-compliant.

Traffic Handling

Non-FIPS traffic is decrypted in FIPS mode. The system is not trusting nor using the monitored traffic except for analysis purposes, and this allows a system in FIPS mode to detect and monitor non-FIPS traffic on the network.

Enabling FIPS Mode

To access the web UI control for enabling and disabling FIPS, click Administration > System Settings: General, then select the Web Server Settings tab and look for the Enable FIPS checkbox. Click it to enable or disable FIPS. (Note that FIPS is disabled by default.) When you change the setting, the web UI will display a banner notifying you that a reboot is needed, and the status dot will turn yellow. The reboot alert is persistent until the reboot is executed. In the Web UI, if the appliance is running in FIPS mode, then 'FIPS Mode' is displayed in the header on the Web UI page. Nothing is displayed in the header if the appliance has FIPS disabled.

Note: Enabling FIPS mode activates the use of FIPS on the system. However, individual features may require additional configuration in order to be properly FIPS-compliant; users are responsible for being familiar with what constitutes FIPS-compliance for each feature, and configuring it appropriately. Refer to comments in the ““Feature Support”” section that follows for more information. Be aware that AppResponse 11 will continue to operate even if one or more features have not been configured for FIPS-compliance; in such a case, the system will not provide any warning that a particular feature is not FIPS-compliant. Any exceptions to this behavior are noted in the “Feature Support” section.

Feature Support

This section details FIPS compliance per feature.

Feature	Supported	Comments
Appliance Licensing	No	None
Backup/Restore	No	See “Backup/Restore”
Email Notifications	Yes	See “Email Notifications”

Feature	Supported	Comments
Encrypted Syslog Notifications	No	See “Encrypted Syslog Notifications”
Integration Links	No	See “Integration Links”
Local Account Passwords	Yes	See “Local Account Passwords”
NetProfiler Integration	Yes	See “NetProfiler Integration”
NTP	Yes	See “NTP”
RADIUS	No	See “RADIUS”
REST API Access	Yes	See “REST API Access”
Secure Vault	Yes	See “Secure Vault”
ServiceNow Notifications	No	None
SNMP	Yes	See “SNMP”
Software Update	No	See “.Software Update”
SSH	Yes	See “SSH”
Syslog Notifications	Yes	See “Syslog Notifications”
TACAC+	No	See “TACACS+”
Web UI	Yes	See “Web UI”

Backup/Restore

Backup/restore to a remote server is not FIPS-compliant. However, note that the server must be configured to allow FIPS-compliant *systems* to connect. Specifically, if the server only allows Diffie-Hellman key exchange algorithms, it must be configured to use approved primes (/etc/ssh/moduli on Red Hat-based systems), or the backup will fail. Either delete the primes file, or enable one or more ecdsa algorithms: ecdsa-sha2-nistp256, ecdsa-sha2-nistp384, ecdsa-sha2-nistp521.

See the Red Hat Customer Portal article on SSH interoperability of RHEL8+ in FIPS mode (RedHat login required).

Email Notifications

No user interaction is necessary; ciphers and algorithms of the outgoing connection are changed to FIPS-compliant ones automatically. The Email server must be configured to support them.

Encrypted Syslog Notifications

Outgoing connection does not disable non-FIPS ciphers.

Integration Links

Communication with other applications that is enabled via the Integration Links page is not FIPS-compliant.

Local Account Passwords

Local passwords are FIPS-compliant, stored as a SHA512-based hash.

NetProfiler Integration

A FIPS-compliant MNMP certificate is used in FIPS mode.

NTP

NTP using either SHA authentication keys or no authentication keys is FIPS-compliant. NTP using MD5 keys is not FIPS-compliant.

RADIUS

The RADIUS protocol is not FIPS-compliant, as it uses a non-compliant hash algorithm.

REST API Access

REST calls use the same HTTPS settings as the web UI, so the web UI must be configured properly, also.

Secure Vault

Secure Vault is FIPS-compliant; no configuration is necessary.

SNMP

When FIPS mode is enabled on the AppResponse 11 appliance, it will change the behavior of some SNMP version 3 functionality. SNMP versions 1 and 2c do not use encryption or hashing and are not affected by FIPS.

Note the following effects when using SNMP version 3:

- NoAuthNoPriv – This is not affected by FIPS.
- AuthNoPriv – Using MD5 as the authentication protocol does not work in FIPS mode. SHA does work, however.
- AuthPriv – Neither MD5 nor SHA works with either privacy protocol in FIPS mode.
- SNMP recipients will not receive notifications when the recipient definition violates FIPS requirements.
- SNMP polling (snmpget/walk/etc.) against an AppResponse 11 system will continue to function even if the polling system's SNMP settings violate FIPS requirements.

.Software Update

Software update is not FIPS-compliant. FIPS must be disabled in order to update the software. Once the update has completed, FIPS may be re-enabled.

SSH

SSH requires the use of one of these ciphers to run in FIPS mode:

- aes128-cbc
- aes192-cbc
- aes256-cbc
- aes128-ctr
- aes192-ctr
- aes256-ctr
- 3des-cbc

The following MACs are allowed in FIPS mode:

- hmac-sha1
- hmac-sha2-256
- hmac-sha2-512

Syslog Notifications

This is unencrypted, and, therefore, FIPS-compliant.

TACACS+

The TACACS+ protocol is not FIPS-compliant, as it uses a non-compliant hash algorithm.

Web UI

Enable only TLSv1.2, and set the cipher string to the FIPS-compatible value "TLSv1.2:kRSA:!eNULL:!aNULL"

You need to ensure imported and generated certificates for the web interface adhere to FIPS size requirements.

How to Report a Discovered Vulnerability

Contact Riverbed technical support to report any security vulnerability that you discover that affects any portion or any operation of the AppResponse 11 system. As much as you're able to do so, please include all details about the circumstances in which you found the vulnerability, including:

- Specific hardware and software versions
- The exploit tool and/or methodology used to discover the vulnerability
- Reference CVE, if known
- Any other information that can be used to reproduce the results

Known vulnerabilities that are addressed by bug fixes in AppResponse 11 are cited as security updates in the release notes for each new AppResponse 11 version.

How to Wipe a System

The CLI command, `system reset-factory` resets the AppResponse 11 system to its factory default state. This command deletes all configuration, data, and logs from the AppResponse 11 system and resets it to the state it was in when it was powered on the very first time. The command does not perform a secure disk wipe or affect the AppResponse 11 software itself; the installed version and any patches will not be touched.